

Security Testing Summary

OWASP Top 10 Based Web Application Security Assessment

1. Objective

The objective of this security testing exercise was to identify common web application vulnerabilities based on the OWASP Top 10, using an intercepting proxy tool (OWASP ZAP / Burp Suite Community Edition) for passive scanning, combined with manual tests for input validation, authentication, and session management weaknesses.

2. Scope

- Application Under Test: [Insert your application name/URL]
- Areas Covered: Login/Logout flow, input fields (search, forms), session handling
- Testing Type: Black-box, manual + tool-assisted (passive scan)
- Tools Used: OWASP ZAP (or Burp Suite Community Edition)

3. Methodology

- 1 Configured browser to route traffic through the intercepting proxy (ZAP/Burp).
- 2 Performed a passive scan by browsing through the application normally, allowing the proxy to analyze traffic for issues.
- 3 Manually tested input fields with common XSS and SQL Injection payloads.
- 4 Tested login/logout flow for authentication weaknesses (e.g. error message details, lockout behavior).
- 5 Tested session behavior: cookie attributes, session timeout, and session reuse after logout.
- 6 Reviewed HTTP response headers for security misconfigurations.

4. OWASP Top 10 Areas Tested

Category	Tested?	Result
Cross-Site Scripting (XSS)	Yes	[Vulnerable / Not Vulnerable]
SQL Injection	Yes	[Vulnerable / Not Vulnerable]
Broken Authentication	Yes	[Findings noted / No major issues]
Sensitive Data Exposure	Yes	[HTTPS used? Data exposed in transit?]

Security Misconfiguration	Yes	[Missing headers / default configs noted]
---------------------------	-----	---

5. Summary of Findings

Replace the table below with your actual results from the Vulnerability Report. This gives a quick at-a-glance view of severity distribution.

ID	Vulnerability	Severity	Status
VULN-01	Reflected XSS	High	Open
VULN-02	SQL Injection	Critical	Open
VULN-03	Weak Session Timeout	Medium	Open
VULN-04	Missing Security Headers	Low	Open

Severity Distribution

Severity	Count
Critical	1
High	1
Medium	1
Low	1

6. Key Risks Identified

- Input fields accept unsanitized data, exposing the application to injection-based attacks (XSS, SQLi).
- Session management does not fully invalidate tokens, risking session hijacking.
- Missing security headers reduce defense-in-depth against client-side attacks like clickjacking.

7. Recommendations

- Sanitize and encode all user input/output to prevent XSS attacks.
- Use parameterized queries everywhere to eliminate SQL Injection risk.
- Enforce a strict session timeout and invalidate tokens server-side on logout.
- Add missing security headers (CSP, X-Frame-Options, X-Content-Type-Options, HSTS).

- Re-test after fixes are applied to confirm vulnerabilities are resolved (regression security testing).

8. Conclusion

The security assessment identified [X] vulnerabilities across Critical, High, Medium, and Low severity levels, primarily related to input validation and session management. Addressing the Critical and High severity findings should be prioritized before the application is considered production-ready. A follow-up retest is recommended once fixes are implemented.